

compliance-coverage

Compliance Standards Coverage

The Preston-Check catalog maps explicitly to six major compliance frameworks and references several others. This document audits which frameworks are well covered, which are partially covered, and which remain gaps.

Currently covered

Preston-Check claims explicit coverage of:

PCI-DSS v4.0 is covered across P-21 (Card Data), P-24 (Data Retention), P-29 (Webhook Signatures), P-35 (Database Encryption), P-37 (Backup & DR), P-58 (Vulnerability Scan Evidence), P-62 (Pentest Evidence), P-83 (Physical Access Evidence), and P-84 (Organizational Policies). The COMPLIANCE_MAPPING.md document tracks the per-control mapping.

SOC 2 Type II trust service criteria are covered across the organizational, technical, and process check categories. P-85 (SOC 2 Availability), P-86 (SOC 2 Confidentiality), and the broader CC, A, P control categories receive attention through the P-83-P-95 evidence verification suite.

ISO 27001:2022 Annex A controls are mapped through P-87 (ISO Organizational), P-88 (ISO People Controls), P-89 (ISO Physical Controls), and the cross-cutting checks that touch A.5–A.8 control families.

NIST CSF 2.0 functions (Govern, Identify, Protect, Detect, Respond, Recover) are mapped through P-90 (NIST Govern), P-91 (NIST Identify), P-92 (NIST Recover), and the cross-cutting Detect and Respond checks.

OWASP API Security Top 10 (2023) receives strong coverage: P-31 (BOLA), P-32 (Mass Assignment), P-33 (Resource Limits), P-34 (SSRF), plus all the broader auth and rate-limit checks mapped to API1–API10.

CIS Controls v8 are covered through P-93 (Asset Inventory), P-94 (Security Training), P-95 (Service Provider Management).

OWASP Top 10 (2021) for traditional web applications is covered through the input validation, auth enforcement, error handling, and data privacy checks.

Partial coverage

GDPR is partially covered through P-61 (Privacy & Consent), P-18 (Data Privacy), P-24 (Data Retention). Gaps remain in DSAR (Data Subject Access Request) workflow correctness, lawful-basis tracking, automated data-portability mechanisms, and DPO designation evidence.

PSD2 (Payment Services Directive 2) is partially covered: P-77 (Withdrawal Controls) references SCA, P-67 (Cross-Account Transfers) references AML 4th Directive. Missing: explicit Strong Customer Authentication enforcement checks, Open Banking RTS/QTSP integration, exemption handling validation.

Travel Rule (FATF Recommendation 16) is referenced in P-77 but lacks a dedicated check for originator/beneficiary information fields on crypto remittances.

OFAC and sanctions regimes are covered by P-72 (Sanctions Screening) but only as a presence check; the depth of OFAC SDN list freshness, PEP database staleness, and country-block correctness is not validated.

SOX 404 internal controls are referenced in P-70 (Settlement Finality), P-75 (Audit Immutability), P-80 (Financial Event Sourcing). Missing: segregation of duties verification, change-management evidence for financial systems, IT general controls (ITGC) evidence.

Major framework gaps

These frameworks are not currently in the catalog and should be on the v1.x roadmap given the project's fintech focus.

DORA (Digital Operational Resilience Act, EU) went into force in January 2025 and applies to a broad range of EU financial entities. It requires ICT risk management, ICT-related incident reporting, digital operational resilience testing (TLPT), ICT third-party risk management, and information sharing arrangements. Preston-Check has elements that touch DORA (incident response in P-40, third-party risk in P-95) but lacks DORA-specific evidence checks for ICT contract registers, threat- led penetration testing programs, and concentration-risk assessments on critical ICT third-party providers.

NIS2 Directive (EU) applies to "essential" and "important" entities across sectors including digital infrastructure and finance. It requires security risk-management measures and 24-hour incident notification. No dedicated NIS2 check exists.

NYDFS Part 500 (23 NYCRR 500) is the cybersecurity regulation for New York-licensed financial institutions, with major 2023 amendments adding CISO requirements, MFA, encryption, asset inventory, and governance reporting. No dedicated check exists, despite this being a material requirement for any US fintech with NY exposure.

FFIEC IT Examination Handbook is the de facto US banking IT-risk framework covering business continuity, information security, audit, and operations. No dedicated checks exist, though many cross-cutting checks touch FFIEC topics implicitly.

MAS TRM (Monetary Authority of Singapore Technology Risk Management Guidelines) is the Singapore standard, increasingly cited as a benchmark across Asia-Pacific fintechs. No dedicated checks exist.

APRA CPS 234 (Australia) mandates information security capability proportionate to risk. No dedicated checks exist.

Reserve Bank of India IT Framework / Cyber Security Framework for NBFCs and payment-system operators is uncovered. Important for any fintech with India exposure.

PCI Software Security Framework (SSF) is the successor to PCI-DSS for software vendors. The Secure SLC and Secure Software requirements overlap with PCI-DSS but have distinct evidence needs. Not separately covered.

PCI 3DS Core Security Standard for 3DS implementations is uncovered.

ISO 22301 (Business Continuity Management) is referenced in P-37 (Backup & DR) but lacks dedicated checks for BIA (business impact analysis) documentation, RTO/RPO evidence, and BCM exercise records.

SOC 1 Type II for financial reporting controls is uncovered.

OWASP Mobile Top 10 (2024) is uncovered. Preston-Check has Flutter/ Dart mobile checks (P-44, P-45) but does not map them to MASVS or M1–M10.

OWASP LLM Top 10 is uncovered. Modern fintechs increasingly use LLM features (KYC document analysis, fraud detection, chatbots) and need specific checks for prompt injection, training-data leakage, PII in prompts, and model output validation.

CSA Cloud Controls Matrix (CCM) is uncovered. Useful for multi- cloud fintech infrastructure security.

HIPAA is out of scope for pure fintech but matters for healthcare- fintech overlaps (HSA providers, telemedicine billing). No checks.

CCPA / CPRA (California) is partially covered through P-61 but lacks California-specific consumer-rights workflow checks.

GLBA Safeguards Rule (US) for non-bank financial institutions and its 2023 expanded requirements. Partially covered through general data-privacy checks but lacks dedicated GLBA evidence verification.

Cyber Essentials / Cyber Essentials Plus (UK) is uncovered.

SLSA (Supply-chain Levels for Software Artifacts) is partially covered through P-41 (Dependency Pinning), P-42 (CI/CD Security), P-63 (Supply Chain Risk) but lacks SLSA-level-specific verification (provenance attestations, hermetic builds).

Sigstore / cosign / in-toto signature verification for build artifacts is uncovered.

Roadmap — compliance coverage

v1.1 — Highest-leverage gaps

Priority: DORA, NYDFS Part 500, OWASP Mobile Top 10, OWASP LLM Top 10. DORA is the highest priority because it took effect in 2025 and applies broadly across EU finance; every European fintech buyer is currently under audit pressure for it. NYDFS is the highest-impact US gap. OWASP Mobile and LLM are growing fast and have minimal coverage anywhere in the market — first-mover advantage exists.

Estimated check count: 20–25 categories across the four frameworks.

v1.2 — Asia-Pacific frameworks

MAS TRM, APRA CPS 234, RBI Cyber Security Framework. Smaller individual markets but cumulatively significant, and currently underserved by existing security tools.

Estimated check count: 15–20 categories.

v1.3 — Specialized financial frameworks

PCI Software Security Framework, PCI 3DS, FFIEC IT Handbook, GLBA Safeguards Rule, ISO 22301 dedicated checks, SLSA-level verification, sigstore/cosign attestation verification.

Estimated check count: 15–20 categories.

v1.4 — Adjacent verticals

NIS2, HIPAA-fintech overlap, CCPA/CPRA dedicated, Cyber Essentials, CSA CCM. Lower priority for the fintech-pure target market but useful for buyers with adjacent regulatory exposure.

Estimated check count: 10–15 categories.

Compliance mapping discipline

Every new check should declare its `frameworks` metadata field with specific regulation citations using the format `Framework:Version:Control` (e.g., `PCI-DSS:4.0:6.5.1`, `SOC2:TSC-2017:CC6.1`, `NIST-CSF:2.0:PR.AC-1`). The compliance evidence package generated by the Pro/Enterprise audit-package layer rolls these citations up into auditor-facing evidence indexes, so consistency in citation format is load-bearing.

When a check legitimately covers multiple controls, list them all. When a control is partially covered, prefer to surface that partial coverage in the check's `description` field rather than over-claiming in the `frameworks` list. Auditors lose trust in tools that claim coverage they don't deliver, and the cost of recovery is high.